



## Domain 1: Security Operations

**Endpoint monitoring** provides important operational information to cybersecurity analysts because endpoint behavior is often the first indicator of a compromise. **Endpoint detection and response (EDR)** systems provide this insight, while **user and entity behavior analytics (UEBA)** solutions allow deeper behavioral inspection.

When monitoring endpoints, watch for cases of deviations from **known good behavior** as well as specific examples of **known malicious behavior**. **Anomaly detection** techniques do not watch for known good or bad behavior but rather monitor for deviations from normal baselines.

**Network monitoring** allows you to determine what systems communicated with each other. **Full packet capture** stores the entire contents of network communication but is intrusive and resource-intensive. **Netflow** records are like a telephone bill, recording information about the nature and length of communication but not storing the actual content.

Records from **domain name system (DNS)** queries help organizations understand what connection attempts were made from their organization. Similarly useful information may come from **content filters** that capture the full URLs of webpages requested by end users. Both of these sources of information may be critical to tracing a malware infection.

**Log review** provides cybersecurity analysts with insight into the behavior of users, systems, and network devices. Logs may be sent to a centralized log repository using the **syslog** protocol.

**Network device logs** often arrive using the **Simple Network Management Protocol (SNMP)** and may be accessed using vendor-specific commands. On Cisco devices, the show logging command provides access to router logs. Cisco devices report log events using a standard system of **log levels** that are numbered in decreasing order of severity:

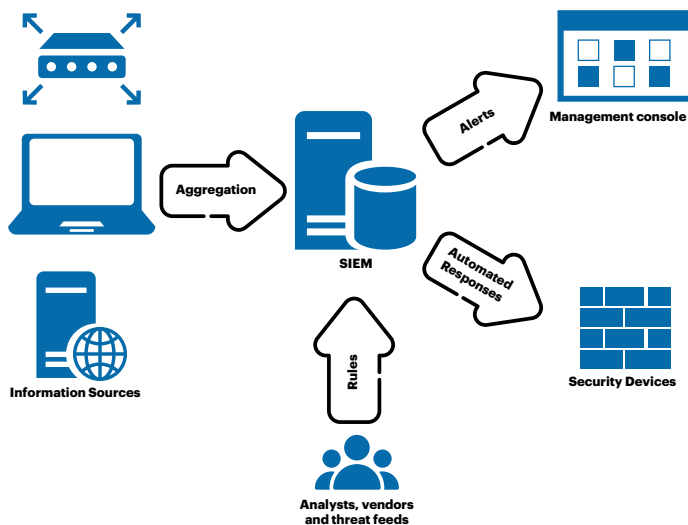
| Level | Name         |
|-------|--------------|
| 0     | Emergency    |
| 1     | Alert        |
| 2     | Critical     |
| 3     | Error        |
| 4     | Warning      |
| 5     | Notification |
| 6     | Information  |
| 7     | Debug        |

The netstat command allows you to view information about network connections on a Windows or Linux system. The nslookup and dig commands allow you to perform DNS lookups, while the traceroute (Linux/Mac) and tracert (Windows) commands allow you to discover the network path between devices.

**Security information and event management (SIEM)** systems perform aggregation and correlation of log entries from different devices, searching for records that, when viewed together, indicate a potential security issue. Automated rules perform the vast majority of SIEM processing but analysts may write manual queries to search for specific information.



## Domain 1: Security Operations



**Security orchestration, automation, and response (SOAR)** platforms take SIEM technology to the next level by incorporating high degrees of automation and coordination between different security solutions. The **Security Content Automation Protocol (SCAP)** facilitates this interconnectivity.

**Email headers** provide information about the path traveled by email messages across the network, although they are susceptible to forgery. **DomainKeys Identified Mail (DKIM)** allows organizations to sign both the body of the message and elements of the header to prove their authenticity. **Sender Policy Framework (SPF)** allows organizations to publish a list of authorized mail servers for their domains. **Domain-based Message Authentication, Reporting, and Conformance (DMARC)** uses SPF and DKIM to determine whether messages are authentic.

| Tool                                                      | Description                                                                                                                   |
|-----------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| <b>Intrusion Detection System</b>                         | Monitors a host or network for signs of intrusion and reports to administrators.                                              |
| <b>Intrusion Prevention System</b>                        | Monitors a host or network for signs of intrusion and attempts to block malicious traffic automatically.                      |
| <b>Security Information &amp; Event Management System</b> | Aggregates and correlates security information received from other systems.                                                   |
| <b>Firewall</b>                                           | Restricts network traffic to authorized connections.                                                                          |
| <b>Application Allow listing</b>                          | Limits applications to those on an approved list.                                                                             |
| <b>Application Block listing</b>                          | Blocks applications on an unapproved list.                                                                                    |
| <b>Sandbox</b>                                            | Provides a safe space to run potentially malicious code.                                                                      |
| <b>Honeypot</b>                                           | System that serves as a decoy to attract attackers.                                                                           |
| <b>Honeynet</b>                                           | Unused network designed to capture probing traffic.                                                                           |
| <b>DNS Sinkhole</b>                                       | Uses false DNS replies to block access to known malicious sites.                                                              |
| <b>VPN Concentrator</b>                                   | Provides a central aggregation point for VPN connections.                                                                     |
| <b>Proxy Server</b>                                       | Makes requests to other servers on behalf of an end user, providing anonymization and performance enhancement.                |
| <b>Data Loss Prevention</b>                               | Blocks the exfiltration of sensitive information from an organization.                                                        |
| <b>Mail Gateway</b>                                       | Screens inbound messages for malicious content.                                                                               |
| <b>Cloud Access Security Broker (CASB)</b>                | Service that intercepts requests headed for cloud services to confirm their compliance with organizational security policies. |
| <b>Hardware Security Module (HSM)</b>                     | Stores and manages encryption keys.                                                                                           |

**Threat hunting** presumes that intruders have already compromised an organization's network and searches for **indicators of compromise** that demonstrate their presence and activity.



## Domain 1: Security Operations

Common **network indicators** of malicious activity include:

- Bandwidth consumption
- Beacons
- Irregular peer-to-peer communication
- Rogue devices
- Scans/sweeps
- Unusual traffic spikes
- Activity on unexpected ports

Common **host-related indicators** of malicious activity include:

- Processor consumption
- Memory consumption
- Drive capacity consumption
- Unauthorized software
- Malicious processes
- Unauthorized changes
- Unauthorized privileges
- Data exfiltration
- Abnormal OS process behavior
- File system changes/anomalies
- Registry changes/anomalies
- Unauthorized scheduled tasks

Common **application-related indicators** of malicious activity include:

- Anomalous application activity
- Introduction of new accounts
- Unexpected output
- Unexpected outbound communication
- Service interruption
- Application logs

**Time synchronization** between systems and services is critical to log analysis. Otherwise, events will not appear in the correct order or at the right times. Clocks should be synchronized using the **Network Time Protocol (NTP)**.

The **Windows Registry** is a database that contains operating system settings. Each root key has Registry hives, which are groups of keys and values that are connected with the root keys.

| Root Key Name                     | Description                                                                   |
|-----------------------------------|-------------------------------------------------------------------------------|
| <b>HKEY_CLASSES_ROOT (HKCR)</b>   | COM object registration information. Associates file types with applications. |
| <b>HKEY_LOCAL_MACHINE (HKLM)</b>  | System information, including scheduled tasks and services.                   |
| <b>HKEY_USERS (HKU)</b>           | Information about user accounts.                                              |
| <b>HKEY_CURRENT_USER (HKCU)</b>   | Information about the currently logged-in user.                               |
| <b>HKEY_CURRENT_CONFIG (HKCC)</b> | Current local hardware profile information storage.                           |

| Common Cybersecurity Tools  |                                                                                                                           |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------|
| Packet Capture Tools        |                                                                                                                           |
| <b>Wireshark</b>            | A graphical packet capture and inspection tool that is available for Linux, Windows, and macOS.                           |
| <b>Tcpdump</b>              | A command-line packet capture tool commonly available on Linux systems but available for other operating systems as well. |
| DNS and IP Reputation Tools |                                                                                                                           |
| <b>WHOIS</b>                | Used for checking an IP address or hostname registration and contact information.                                         |
| <b>AbuseIPDB</b>            | Used for searching IP addresses, domains, or networks to see if they've been reported for abuse.                          |
| File Analysis Tools         |                                                                                                                           |
| <b>Strings</b>              | Extracts text strings from a binary file.                                                                                 |
| <b>VirusTotal</b>           | Website that performs analysis of suspected malware files.                                                                |
| Sandboxing                  |                                                                                                                           |
| <b>Joe Sandbox</b>          | A commercial sandbox service with a free basic option that can test against multiple operating systems.                   |
| <b>Cuckoo Sandbox</b>       | An automated malware analysis tool that you can run as a self-hosted tool.                                                |



## Domain 1: Security Operations

**Threat intelligence** provides cybersecurity analysts with insight into the nature of external threats and the tools, techniques, and procedures used by those threats.

Organizations may purchase **proprietary/closed-source** intelligence from commercial vendors and/or make use of free **open-source intelligence** developed by the security community. Cybersecurity analysts may engage in industry-specific **information sharing and analysis communities (ISACs)** to exchange threat information with peers.

Be familiar with the most common types of **threat actors** facing modern organizations:

- **Advanced Persistent Threats (APTs)** are sophisticated attackers with highly focused objectives and advanced skills.
- **Nation-state actors** are government-sponsored cyberattackers with access to vast resources.
- **Hacktivists** are attackers who have a motivation centered on political activism.
- **Script kiddies/unskilled attackers** are generally low-ability attackers seeking a quick thrill.
- **Organized crime** groups use cyberattacks for financial gain.
- **Insider threats** come from employees or other stakeholders who undermine security, either accidentally or intentionally.
- **Supply chain** threats compromise systems or software before it reaches the end user.

When assessing the value of an intelligence source, analysts should consider the intelligence's **timeliness**, **relevance**, and **accuracy** to determine how much weight to assign it.

The **intelligence cycle** describes the process of intelligence analysis, from requirements gathering through feedback. There are five stages to the intelligence cycle:



When automating threat intelligence processing, organizations rely upon the **Structured Threat Information Expression (STIX)** standard: an XML language used to describe threat components and their relationships. The **Trusted Automated Exchange of Intelligence Information (TAXII)** protocol allows the automated exchange of STIX data between cybersecurity components.

In **virtualized environments**, many guest systems run on a single piece of hardware. The **hypervisor** is responsible for separating resources used by different guests. **Type 1 hypervisors** run directly on the “bare metal” hardware while **type 2 hypervisors** run on a host operating system.

**Application virtualization** virtualizes individual software apps instead of entire operating systems, presenting them to the user through a web-based or other interface. **Virtual desktop infrastructure (VDI)** creates entire user workstations in the cloud.



## Domain 1: Security Operations

When deploying services in the cloud, organizations may choose from three major cloud strategies:

- **Software-as-a-Service (SaaS)** deploys entire applications to the cloud. The customer is only responsible for supplying data and manipulating the application.
- **Infrastructure-as-a-Service (IaaS)** sells basic building blocks, such as servers and storage. The customer manages the operating system and configures and installs software.
- **Platform-as-a-Service (PaaS)** provides the customer with a managed environment to run their own software without concern for the underlying hardware.

Cloud services may be built and/or purchased in several forms:

- **Public cloud** providers sell services to many different customers and many customers may share the same physical hardware.
- **Private cloud** environments dedicate hardware to a single user.
- **Hybrid cloud** environments combine elements of public and private cloud in a single organization.
- **Community cloud** environments use a model similar to the public cloud but with access restricted to a specific set of customers.

**Serverless computing** is a cloud service offering that allows customers to execute functions as a service. Customers provide the code and the cloud provider executes that code on an as-needed basis.

**Zero trust** networking removes the trust that used to be placed in systems, services, and individuals inside security boundaries. In a zero trust environment, each action requested and allowed must be verified and validated before being allowed to occur. **Secure access service edge (SASE)** leverages software-defined WAN and security functionality like CASBs, zero trust, firewall as a service, antimalware tools, and other capabilities. SASE focuses on ensuring security at the endpoint and network layer.

**Network segmentation** places different types of systems on different network segments, minimizing the likelihood of cross-infection. This may be done with physically separate networks or with virtual networks (**VLANs**). Extremely sensitive network segments may be separated by an **air gap**, meaning they are not connected to any other network. **Virtual private clouds (VPCs)** are used to create virtual network segmentation in cloud environments.

**Virtual private networks (VPNs)** use encryption to connect remote network segments together and to connect remote users to enterprise networks.

The **hardware root of trust** is established through the use of the **trusted platform module (TPM)** and provides assurance that hardware has not been tampered with. The boot process for a system is managed by the **Unified Extensible Firmware Interface (UEFI)** which replaces the older BIOS approach. High security applications may require the use of a **trusted foundry** for chips that establishes a high degree of assurance that the chip was securely built.

The core activities of identity and access management are:

- **Identification** where a user makes a claim of identity.
- **Authentication** where the user proves the claim of identity.
- **Authorization** where the system confirms that the user is permitted to perform the requested action.

In access control systems, we seek to limit the access that **subjects** (e.g. users, applications, processes) have to **objects** (e.g. information resources, systems)

Access controls work in three different fashions:

- **Technical (or logical) controls** use hardware and software mechanisms, such as firewalls and intrusion prevention systems, to limit access.
- **Physical controls**, such as locks and keys, limit physical access to controlled spaces.



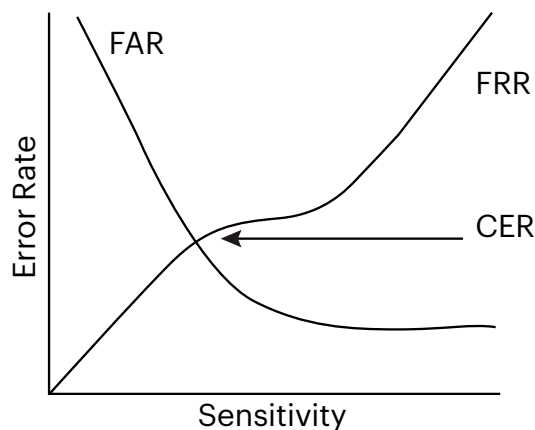
## Domain 1: Security Operations

- **Administrative controls**, such as account reviews, provide management of personnel and business practices.

Multifactor authentication systems combine authentication technologies from two or more of the following categories:

- **Something you know** (Type 1 factors) rely upon secret information, such as a password.
- **Something you have** (Type 2 factors) rely upon physical possession of an object, such as a smartphone.
- **Something you are** (Type 3 factors) rely upon biometric characteristics of a person, such as a face scan or fingerprint.

Authentication technologies may experience two types of errors. **False positive** errors occur when a system accepts an invalid user as correct. It is measured using the false acceptance rate (FAR). **False negative** errors occur when a system rejects a valid user, measured using the false rejection rate (FRR). We evaluate the effectiveness of an authentication technology using the **crossover error rate (CER)**, as shown in the diagram below:



**RADIUS** is an authentication protocol commonly used for backend services. **TACACS+** serves a similar purpose and is the only protocol from the TACACS family that is still commonly used.

The **Security Assertion Markup Language (SAML)** provides an open standard for different entities to exchange authentication and authorization information when performing federation.

**OAuth** is an authorization standard that allows users to log into applications using credentials provided by other identity providers without providing the application with those credentials. **OpenID Connect** is a consumer-focused implementation of OAuth used by Google and other cloud service providers.

**Access control lists (ACLs)** form the basis of many access management systems and provide a listing of subjects and their permissions on objects and groups of objects.

**Discretionary access control (DAC)** systems allow the owners of objects to modify the permissions that other users have on those objects. **Mandatory access control (MAC)** systems enforce predefined policies that users may not modify.

**Role-based access control** assigns permissions to individual users based upon their assigned role(s) in the organization. For example, backup administrators might have one set of permissions while sales representatives have an entirely different set.

**Attribute-based access control (ABAC)** systems make access control decisions based upon characteristics of the user, system, information, or other attributes.

**Risk-based access control** systems vary their access control decisions based upon the current threat environment.

**Rule-based access control** systems make access control decisions based upon a set of predefined rules. Firewalls are a common example.



## Domain 1: Security Operations

You should try to improve the **efficiency** of your security operations by conducting process improvement efforts.

- **Standardize processes** as much as possible.  
Identify tasks that are repeatable and do not require human interaction as they are often automatable.  
Coordinate with the team to manage and facilitate automation.
- **Streamline operations** by using SOAR technology and automating threat intelligence activities to minimize human engagement.
- **Integrate** technologies and tools using **APIs**, **webhooks**, and **plugins**. The goal is to achieve a **single pane of glass** approach to monitoring and managing the security infrastructure.

| Port(s)                 | Service               |
|-------------------------|-----------------------|
| 20, 21                  | FTP                   |
| 22                      | SSH                   |
| 23                      | Telnet                |
| 25                      | SMTP                  |
| 53                      | DNS                   |
| 80                      | HTTP                  |
| 110                     | POP3                  |
| 123                     | NTP                   |
| 135, 137, 138, 139, 445 | Windows File Sharing  |
| 143                     | IMAP                  |
| 161/162                 | SNMP                  |
| 443                     | HTTPS                 |
| 636                     | LDAPS                 |
| 1433/1434               | SQL Server            |
| 1521                    | Oracle                |
| 1720                    | H.323                 |
| 1723                    | PPTP                  |
| 3389                    | RDP                   |
| 9100                    | HP JetDirect Printing |



## Domain 2: Vulnerability Management

The **Common Vulnerability Scoring System (CVSS)** rates the severity of security vulnerabilities based upon eight criteria:

1. Attack Vector (AV)
2. Attack Complexity (AC)
3. Privileges Required (PR)
4. User Interaction (UI)
5. Scope (S)
6. Confidentiality Impact (C)
7. Integrity Impact (I)
8. Availability Impact (A)

The CVSS base score combines all eight of these factors into a single score from 0.0 to 10.0, with the following severity descriptions:

| CVSS Score | Rating   |
|------------|----------|
| 0.0        | None     |
| 0.1-3.9    | Low      |
| 4.0-6.9    | Medium   |
| 7.0-8.9    | High     |
| 9.0-10.0   | Critical |

**Network vulnerability scanning** first discovers active services on the network and then probes those services for known vulnerabilities. **Web application vulnerability scans** use tools that specialize in probing for web application weaknesses.

The vulnerability management workflow includes three basic steps: **detection**, **remediation**, and **validation**.

Be familiar with common vulnerability assessment tools and interpreting their output:

| Network Scanning & Mapping | Web Scanners | Vulnerability Scanners | Debuggers | Multipurpose               | Cloud Assessment |
|----------------------------|--------------|------------------------|-----------|----------------------------|------------------|
| Angry IP                   | Burp Suite   | Nessus                 | Immunity  | Nmap                       | Scout Suite      |
| Maltego                    | OWASP ZAP    | OpenVAS                | GDB       | Metasploit Framework (MSF) | Prowler          |
|                            | Nikto        |                        |           | Recon-ng                   | Pacu             |

**Active scanning** techniques engage with the target system to probe it for known vulnerabilities while **passive scanning** techniques are stealthier. Passive scans do not engage with the target system but attempt to identify vulnerabilities by observing network traffic and other system characteristics.

When validating a vulnerability report, there are four possible outcomes:

|                               |     | Does the vulnerability actually exist? |                       |
|-------------------------------|-----|----------------------------------------|-----------------------|
|                               |     | Yes                                    | No                    |
| Was a vulnerability reported? | Yes | <b>True Positive</b>                   | <b>False Positive</b> |
|                               | No  | <b>False Negative</b>                  | <b>True Negative</b>  |



## Domain 2: Vulnerability Management

Common parameters that you may tune when configuring vulnerability scans include:

- Using **credentialled scans** to log onto target systems and improve scan accuracy
- Using a combination of **server-based** scans that run over the network and **agent-based** scans that run on the local system.
- Using different scan perspectives to determine the **external** view that an outside attacker would see and the **internal** view available to an insider or an attacker that has already gained a foothold on the network

When assessing software security, **static analysis** techniques perform analysis of code without actually executing the code, while **dynamic analysis** techniques execute the code and monitor its activity. Strong assessments combine both static and dynamic techniques.

**Fuzzing** is a common dynamic analysis technique that supplies machine-generated input to applications in an attempt to undermine security.

**Reverse engineering** techniques seek to decompile executable code to gain access to the original source code or assembly language.

| Attack Type                       | Description                                                                                                                                                                                                 |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>SQL injection</b>              | Manipulates web applications to send unauthorized commands to the back-end database                                                                                                                         |
| <b>Overflow</b>                   | Places more data than expected in a memory buffer in an attempt to execute unauthorized code                                                                                                                |
| <b>Remote code execution</b>      | Allows an attacker to execute code of their choosing without accessing the system directly                                                                                                                  |
| <b>Directory traversal</b>        | Embeds periods and slashes in URLs in an attempt to navigate the web server's file system                                                                                                                   |
| <b>Privilege escalation</b>       | Exploits that allow an attacker to take a normal user account and manipulate it to gain administrative access. Often performed using a rootkit.                                                             |
| <b>Password spraying</b>          | Attempts to access a large number of accounts by trying commonly used passwords                                                                                                                             |
| <b>Credential stuffing</b>        | Attempts to access accounts belonging to a specific user with username/password combinations exposed in the breach of another site. Effective because users reuse the same passwords in multiple locations. |
| <b>Impersonation</b>              | Attacks where the attacker is able to appear to a remote user/system as another individual.                                                                                                                 |
| <b>On-path attack</b>             | Formerly known as man-in-the-middle attacks. Eavesdropping attack where the attacker inserts themselves into the middle of an encrypted communications channel.                                             |
| <b>Session hijacking</b>          | Attacks where the adversary steals a cookie or other session credential to take over a user's existing authenticated session.                                                                               |
| <b>Cross-site scripting (XSS)</b> | Attack where the adversary tricks the user's browser into executing embedded scripts that are either stored on a web server (persistent XSS) or use input that is repeated as output (reflected XSS).       |

Many of these attacks arise due to a set of common vulnerabilities that exist in source code:

- Improper error handling
- Insecure pointer dereferencing
- Race conditions
- Broken authentication
- Sensitive data exposure
- Insecure components
- Insufficient logging and monitoring
- Weak or default configurations
- Use of insecure functions (especially strcpy)



## Domain 2: Vulnerability Management

Security controls are divided into three categories, based upon how they function:

| Category           | Description                                                                      |
|--------------------|----------------------------------------------------------------------------------|
| <b>Managerial</b>  | Procedural mechanisms that focus on the mechanics of the risk management process |
| <b>Operational</b> | Processes that we put in place to manage technology in a secure manner           |
| <b>Technical</b>   | Use technological means to meet a security objective                             |

We can also classify security controls into six different types, based upon what they are designed to achieve:

| Type                | Description                                                                                        |
|---------------------|----------------------------------------------------------------------------------------------------|
| <b>Preventative</b> | Stops an adversary from violating security policies                                                |
| <b>Detective</b>    | Identifies potential violations of security policies                                               |
| <b>Corrective</b>   | Restores the original state after a security incident                                              |
| <b>Responsive</b>   | Counteracts or responds to a detected security incident in real-time to limit its immediate impact |
| <b>Compensating</b> | Fills the gap left when it is not possible to implement a required control                         |
| <b>Physical</b>     | Uses physical constraints to meet a security objective                                             |

**Privacy** and **security** are closely related but have different objectives. Security controls seek to protect the confidentiality, integrity, and availability of information belonging to the organization. Privacy focuses on the protection of individuals by limiting the ways that the organization can collect, store, and use personal information. **Purpose limitation** is a core privacy concept that says organizations may only use data for the purposes they disclosed when collecting it.

**Risks** are the combination of a **threat** and a corresponding **vulnerability**.

Quantitative risk assessment uses the following formulas:

$$\begin{aligned} \text{SingleLossExpectancy} &= \text{AssetValue} * \text{ExposureFactor} \\ \text{AnnualizedLossExpectancy} &= \text{AnnualizedRateofOccurrence} * \text{SLE} \end{aligned}$$

Responses to a risk include:

- **Avoid** risk by changing business practices
- **Mitigate** risk by implementing controls
- **Accept** risk and continue operations
- **Transfer** risk through insurance or contract

| Data Role             | Description                                                          |
|-----------------------|----------------------------------------------------------------------|
| <b>Data Owner</b>     | Senior-level executive who establishes rules and determines controls |
| <b>System Owner</b>   | Individual responsible for overseeing secure operation of systems    |
| <b>Data Processor</b> | Individual with access to personal or sensitive information          |

**Data minimization** techniques lower risk by decreasing the amount of sensitive information maintained by the organization. When data can't be eliminated, **data obfuscation** techniques may render it less sensitive.

Data obfuscation techniques include:

- Hashing uses a hash function to transform a value in our dataset to a corresponding hash value.
- Tokenization replaces sensitive values with a unique identifier using a lookup table.
- Masking partially redacts sensitive information by replacing some or all of sensitive fields with blank characters.

**Data retention** standards describe how long the organization should preserve records. Data that is no longer needed should be securely destroyed. The principle of **data sovereignty** says that data is subject to the legal requirements of any jurisdiction where it is collected, stored, processed, or transmitted. Security **frameworks** provide templates for security activities. These include COBIT, NIST CSF, and ISO 27001/2.

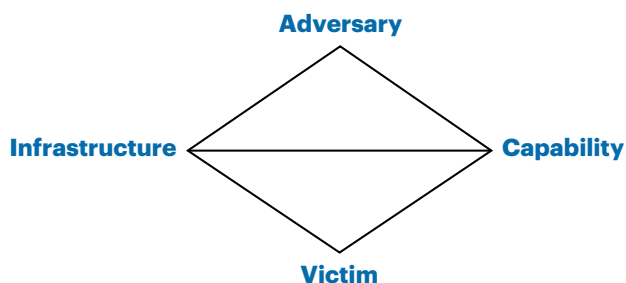
**Due care** is taking reasonable steps to protect the interest of the organization. **Due diligence** ensures those steps are carried out.



## Domain 3: Incident Response and Management

MITRE's Adversarial Tactics, Techniques, and Common Knowledge (**ATT&CK**) framework is a collection of information about the techniques used by attackers seeking to gain access to an organization and its systems.

The **Diamond model** provides an approach for modelling attacks by describing the relationship between the adversary, victim, infrastructure, and capabilities, as shown here:

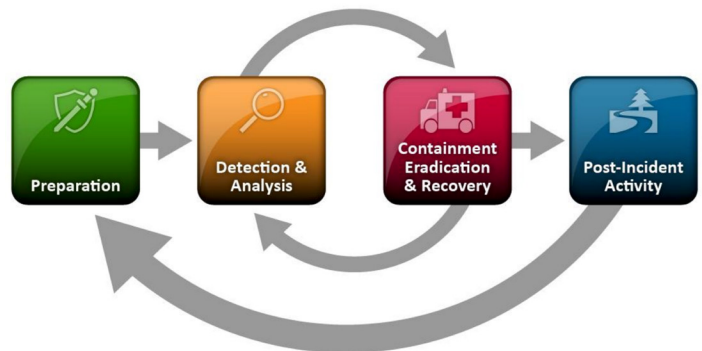


The last threat model you should be familiar with is the Lockheed Martin **Cyber Kill Chain**. This approach models adversary activities as a seven-step process:



Threat intelligence should be shared with other relevant functions within the organization, including incident response, vulnerability management, risk management, security engineering, and detection & monitoring.

When responding to a **security incident**, be prepared to use the NIST four-stage process:



As you prepare for an incident response effort, you should develop an **incident communication plan** that uses secure means of communication to **limit communication** to trusted parties and prevent the inadvertent release of information.

Generally, you are not required to disclose security incidents to law enforcement unless you choose to do so or are subject to **legal or regulatory requirements**.

Your **incident response team** should include representatives from all relevant internal teams:

- Cybersecurity
- Other technology experts
- Legal
- Human resources
- Public relations
- Senior leadership



# Domain 3: Incident Response and Management

You should also have your team prepared to **coordinate** with external groups that are not represented directly on the team, including law enforcement and regulatory bodies.

Incident response plans should base the severity of an incident on the criticality of data involved, paying particular attention to:

- Personally identifiable information (PII)
- Protected health information (PHI)
- Personal financial information
- Sensitive personal information (SPI)
- Intellectual property and other corporate high-value assets

The **preparation phase** of incident response should include **training**, **testing**, and **documentation** of procedures.

The **detection and analysis phase** of incident response determines that an incident is underway and determines the severity level and appropriate response.

The objective of the **containment phase** is to limit the damage caused by the incident through the isolation of affected systems and assets. This is closely linked to **eradication and recovery** efforts that seek to restore normal operations.

During the **post-incident activities phase**, the organization conducts a lessons learned process, updates change management records, determines what evidence should be retained, writes an incident report, and makes any necessary updates to the incident response plan.

When acquiring evidence, **preserve** data by acquiring it, validating the acquisition, and storing it in a secure and documented manner. Preserve the **chain of custody**, tracking evidence through its life cycle, including the collection, preservation, and analysis of the evidence.

When an organization expects litigation, **legal holds** notify data custodians to preserve data, including data that might otherwise have been deleted or removed as part of normal business processes.

**Playbooks** are step-by-step recipe-style responses to cybersecurity incidents. They should guide the team's response, but they are not a substitute for professional judgment.

The goal of the **business continuity** program is to ensure that the organization is able to maintain normal operations even during an unexpected event. The goal of the **disaster recovery** program is to help the organization quickly recover normal operations if they are disrupted.



## Domain 4: Reporting and Communication

**Vulnerability reporting** should include several elements:

- Listing of vulnerabilities
- Affected hosts
- Risk scores (e.g. CVSS)
- Mitigation opportunities
- Recurrence data
- Prioritization of vulnerabilities
- Configuration management updates
- Patching of vulnerable systems
- Compensating controls for systems that cannot be patched
- Awareness, training, and education efforts for affected staff
- Changing business requirements when necessary

Cybersecurity leaders in regulated industries should produce **compliance reports** that document specific vulnerabilities that require remediation in order to comply with industry regulations/standards.

**Action plans** for vulnerability remediation should include:

It is not always possible to remediate vulnerabilities and cybersecurity analysts commonly face **inhibitors to remediation** efforts. Common inhibitors include:

- Possible memoranda of understanding (MOU) breaches
- Possible service level agreement (SLA) breaches
- Organizational governance controls
- Potential for business process interruption
- Potential for degrading functionality
- Legacy systems that are difficult/impossible to remediate

| Vulnerability Management Metrics and Key Performance Indicators (KPIs) |                                                                                                                                                                                                                                                                                                                                                                                                     |
|------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Trends</b>                                                          | <ul style="list-style-type: none"><li>• Focus on the number of vulnerabilities, their severity or risk rating, and the time to remediate. Issues with recurrence and also frequent targets of reports, although recurrence should be low or zero in most organizations.</li></ul>                                                                                                                   |
| <b>Top 10 lists</b>                                                    | <ul style="list-style-type: none"><li>• Help identify the biggest threats, most common vulnerabilities, and similar items that can be useful for focusing organizational resources.</li></ul>                                                                                                                                                                                                       |
| <b>Critical vulnerabilities</b>                                        | <ul style="list-style-type: none"><li>• Vulnerabilities that are likely to result in exploit and that could have significant impact.</li></ul>                                                                                                                                                                                                                                                      |
| <b>Zero-days</b>                                                       | <ul style="list-style-type: none"><li>• Vulnerabilities that are discovered before they are patched. This allows attackers to exploit the vulnerability until a patch is created and deployed. Since they are unknown, they cannot be identified by configuration management systems or vulnerability scanners until those systems receive updated definitions or detection capabilities.</li></ul> |
| <b>Service level objectives (SLOs)</b>                                 | <ul style="list-style-type: none"><li>• Describe specific metrics like time to remediate or patch, and they are set by an organization or are defined as part of a service level agreement with a vendor or service. Measuring whether SLOs are being met and where gaps exist is a common element of SLA management.</li></ul>                                                                     |



## Domain 4: Reporting and Communication

When creating an **incident report**, include the following standard elements:

- Executive summary
- Who, what, when, where, and why
- Recommendations for improvement
- Timeline of the incident
- Impact of the incident
- Scope of the incident
- Evidence

Incident response metrics are essential for effective cybersecurity management, providing a quantifiable measure of how well an organization's security posture holds up against threats and attacks.

- **Mean Time to Detect (MTTD)** measures the average time it takes for an organization to detect a security incident or breach, indicating the efficiency of detection systems and processes.
- **Mean Time to Respond (MTTR)** quantifies the average time it takes to respond to a detected security incident, reflecting the speed and effectiveness of the incident response team.
- **Mean Time to Remediate (MTTRm)** denotes the average time taken to fix or remediate a vulnerability or a breach, highlighting the efficacy of an organization's incident recovery processes.
- **Alert Volume** tracks the total number of security alerts generated over a certain period, providing insight into the overall security status and the potential workload of the incident response team.

Security governance is carried out through

- **Policies** which state high-level objectives (mandatory compliance).
- **Standards** which state detailed technical requirements (mandatory compliance).
- **Procedures** which provide step-by-step processes (mandatory compliance).
- **Guidelines** which offer advice and best practices (optional compliance).

Security baselines, such as **NIST SP 800-53**, provide a standardized set of controls that an organization may use as a benchmark.

Typically, organizations don't adopt a baseline standard wholesale, but instead tailor a baseline to meet their specific security requirements.

Audits of cloud service providers and other managed service providers should take place using the System and Organization Controls (**SOC**) standard, published in the Statement on Standards for Attestation Engagements #18 (SSAE 18).

There are three categories of SOC audits:

- **SOC 1** audits provide customers with the level of assurance they need when conducting their own financial audits.
- **SOC 2** audits evaluate the service provider's confidentiality, integrity, and availability controls. They contain sensitive information.
- **SOC 3** audits also evaluate confidentiality, integrity, and availability but are meant for public disclosure.

And there are two types of SOC 1 and SOC 2 audits:

- **Type I audits** describe the controls that the service provider has in place and offer an opinion on their suitability, but not their effectiveness.
- **Type II audits** describe the controls that the service provider has in place, offer an opinion on their suitability, and also provide the results of auditors' effectiveness tests.

SOC 1 and 2 audits can have type I or II reports. SOC 3 audits do not have different type reports.